

Case study -

An example Incident Response Plan

1. The person who discovers the incident will contact the IR team. (Include the names and 24/7 contact details for the IR team.)

2. If the person discovering the incident is a member of the IT department or affected department, they will proceed to step 4.

3. If the person discovering the incident is not a member of the IT department or affected department, they will call the 24/7 IT emergency contact, who will log:

- the name of the caller
- time of the call
- contact information about the caller
- the nature of the incident
- what equipment or persons were involved
- location of equipment or persons involved
- how the incident was detected
- when the event was first noticed that supported the idea that the incident occurred

4. The IT staff member who receives the call or discovered the incident will refer to their contact list for information on who to contact and contact details. The staff member will contact the incident response manager using both email and phone messages. The staff member could add the following information:

- whether the equipment affected is business critical
- the severity of the potential impact
- name or type of system being targeted, along with operating system, IP address, and location
- IP address and any information about the origin of the attack

5. Contacted members of the IR team will meet or discuss the situation and determine a threat level response strategy. The following should be considered when determining the threat level:

Continued..

- Is the incident real or perceived?
- Is the incident still in progress?
- What data or property is threatened and how critical is it?
- What is the impact on the business should the attack succeed? Minimal, serious, or critical?
- What system or systems are targeted, where are they located physically and on the network?
- Is the incident inside the trusted network?
- Is the response urgent?
- Can the incident be quickly contained?
- Will the response alert the attacker and do we care?
- What type of incident is this? Example: virus, worm, intrusion, abuse, damage.

6. An incident ticket will be created. The incident will be a threat level:

Low: Minimal, if any, impact; one or two non-sensitive/non-critical devices affected; fewer than 10 percent of non-critical staff affected.

Medium: 20% of staff unable to work; possible breach of small amounts of non-sensitive data; low risk to reputation; small number of non-critical systems affected with known resolutions.

High: 50% of staff unable to work; risk of breach of personal or sensitive data; non-critical systems affected, or critical systems affected with known resolution; some financial impact; potential serious reputational damage; potential regulatory involvement.

Critical: Majority of staff unable to work; critical systems offline with no known resolution; high risk to or definite breach of sensitive client or personal data; financial impact; severe reputational damage – likely to impact business long term.

7. The IT/IR team will follow one of the following procedures, basing their response on the incident assessment:

- Worm response procedure
- Virus response procedure
- System failure procedure
- Active intrusion response procedure – is critical data at risk?
- Inactive intrusion response procedure
- System abuse procedure
- Property theft response procedure

Continued..

- Website denial of service response procedure
- Database or file denial of service response procedure
- Spyware response procedure

If there is no applicable procedure in place, the team must document what was done and later establish a procedure for the incident.

8. Team members will use forensic techniques, including reviewing system logs, looking for gaps in logs, reviewing intrusion detection logs, and interviewing witnesses and the incident victim to determine how the incident was caused. Only authorised personnel should be performing interviews or examining evidence, and the authorised personnel may vary by situation and the organisation.

9. Team members will recommend changes to prevent the occurrence from happening again or infecting other systems.

10. On management approval, the changes will be implemented.

11. Team members will restore the affected system(s) to the uninfected state. They may do any or more of the following:

- Re-install the affected system(s) from scratch and restore data from backups if necessary.
- Preserve evidence before doing this.
- Make users change passwords if passwords may have been sniffed.
- Be sure the system has been hardened by turning off or uninstalling unused services.
- Be sure the system is fully patched.
- Be sure real-time virus protection and intrusion detection is running.
- Be sure the system is logging the correct events and to the proper level.

12. Documentation – the following shall be documented:

- how the incident was discovered
- the category of the incident
- how the incident occurred, whether through email, firewall, etc.
- where the attack came from, such as IP addresses and other related information about the attacker
- what the response plan was
- what was done in response
- whether the response was effective

13. Evidence Preservation – make copies of logs, email, and other communication. Keep lists of witnesses. Keep evidence as long as necessary to complete prosecution and beyond in case of an appeal.

14. Notify proper external agencies – notify the police and other appropriate agencies if prosecution of the intruder is possible. List the agencies and contact numbers here.

15. Assess damage and cost – assess the damage to the organisation and estimate both the damage cost and the cost of the containment efforts.

16. Review response and update policies – plan and take preventative steps so the intrusion can't happen again.

- Consider whether an additional policy could have prevented the intrusion.
- Consider whether a procedure or policy was not followed which allowed the intrusion, and then consider what could be changed to ensure that the procedure or policy is followed in the future.
- Was the incident response appropriate? How could it be improved?
- Was every appropriate party informed in a timely manner?
- Were the incident-response procedures detailed and did they cover the entire situation? How can they be improved?
- Have changes been made to prevent a re-infection? Have all systems been patched, systems locked down, passwords changed, anti-virus updated, email policies set, etc.?
- Have changes been made to prevent a new and similar infection?
- Should any security policies be updated?
- What lessons have been learned from this experience?